

The Governance Receipt

A Chain-of-Custody Framework for Accountable AI in Healthcare and Law

A white paper for independent medical practices, small law firms, compliance leaders,
and investors evaluating evidence-preserving AI infrastructure.

No governance receipt, no accountable AI.

GOVERNANCE RECEIPT

Identity	_____
Task	_____
Evidence	_____
Generation	_____
Review	_____
Output	_____
Audit trail	_____
Data boundary	_____

Executive Summary

The first wave of generative AI was about access: Can the model answer? The next wave, especially in healthcare and law, will be about accountability: Can the organization prove how the answer was created?

This white paper introduces the Governance Receipt: a chain-of-custody framework for consequential AI outputs. A governance receipt is the record that connects user identity, prompt, retrieved evidence, generated draft, human review, final output, export event, and data-boundary proof into a reconstructable trail.

The framework is grounded in established expectations from AI risk management, healthcare security, auditability, and legal professional responsibility. NIST frames trustworthy AI around attributes such as accountability, transparency, explainability, privacy, security, and resilience (National Institute of Standards and Technology [NIST], 2023). HIPAA's Security Rule requires audit controls for systems that contain or use electronic protected health information (45 C.F.R. § 164.312(b)). Legal ethics guidance for generative AI emphasizes competence, confidentiality, communication, supervision, and reasonable fees when lawyers use these tools (American Bar Association, 2024).

The implication is practical: policies are necessary, but policies alone do not create evidence. A policy says what people are supposed to do. A governance receipt shows what actually happened.

Pocono AI's Sentinel Node is positioned for this standard: local retrieval, local inference, citation-bound output, human professional review, and local audit logging. The purpose is not to replace physicians, attorneys, or staff. It is to make AI-assisted work reconstructable, reviewable, and defensible.

No governance receipt, no accountable AI.

Quick Findings

Finding	Why it matters
AI governance is becoming evidence-centric.	Organizations need reconstructable proof, not only acceptable-use rules.
Hallucination is only one failure mode.	A correct answer can still be ungovernable if evidence, review, and data path cannot be reconstructed.
Healthcare creates the clearest use cases.	Prior authorization, denials, chart summaries, and referral letters all touch sensitive information and professional judgment.
Local architecture can reduce ambiguity.	Keeping retrieval, inference, review, and logging inside the organization makes the data boundary easier to manage.

1. The Governance Question Is Changing

Most organizations still begin their AI conversations with permission: Which tools are allowed? Which uses are prohibited? What should employees avoid? Those questions matter, but they are no longer sufficient for regulated work.

In high-liability environments, the better question is whether the organization can prove what happened after AI was used. A consequential AI output is not just text. It is an event. It has a user, a task, a data context, a retrieval path, a model-generated draft, a human review step, a final output, and a data boundary.

That event needs evidence. Otherwise, the organization may have AI activity without accountable AI governance.

2. Why Prior Authorization Is the Lead Use Case

Prior authorization is a clear place to understand the governance problem. It is document-heavy, staff-intensive, payer-specific, and clinically consequential. A well-designed AI system can help summarize chart history, identify relevant clinical facts, compare the request against payer criteria, draft an appeal letter, and prepare the clinician for final review.

But every one of those steps raises accountability questions. Which chart notes were retrieved? Which payer policy was used? What version of that policy existed at the time? What did the AI draft? Which claims were supported by citations? Who reviewed the output? What was sent? Did protected health information leave the practice?

Without those answers, a useful workflow can become an undocumented event. In healthcare, undocumented events can become compliance gaps, liability gaps, patient-safety gaps, and trust gaps.

3. Hallucination Is Only One Failure Mode

Hallucination matters. A false medical fact, incorrect payer criterion, fabricated citation, or invented legal reference can cause real harm. But hallucination is not the whole problem.

The quieter governance failure is an answer that is mostly right but cannot be reconstructed. The system may use stale evidence, mix contexts, omit key documents, or produce a plausible draft with no record of which sources supported it. A person may review the answer, but the system may not preserve what the reviewer saw or changed.

A hallucination is a bad answer. A missing chain of custody is a bad system. The first is an output problem. The second is an architecture problem.

4. Policy-Only Governance Is Not Enough

Organizations often respond to AI by writing rules: do not paste sensitive data into public systems, do not rely on uncited outputs, do not use AI for final clinical or legal decisions, and always have a human review important work.

Those policies are necessary. But they do not automatically create proof. They tell people what they should do; they do not show what actually happened.

Policy-only AI says: Trust us. Governed AI says: Here is the receipt.

Simple metaphor: A policy is a promise. A receipt is evidence.

5. The Governance Receipt Model

A governance receipt should preserve a chain of custody for the AI-assisted event. It does not need to be complicated for the user. It does need to be complete enough for later review, investigation, improvement, and defense.

Layer	Receipt evidence captured	Governance purpose
Identity	User, role, authentication context	Shows who initiated or reviewed the event.
Task	Prompt, workflow, patient/matter context	Shows what the system was asked to do.
Evidence	Retrieved records, passages, documents, policy version	Shows what the answer was grounded in.
Generation	Model, parameters if applicable, draft output	Shows what AI produced before human action.
Review	Reviewer, approval/rejection, edits, timestamp	Preserves human professional accountability.
Output	Final message, letter, summary, export record	Shows what left the workflow.
Audit trail	Immutable or tamper-evident event log	Supports reconstruction and investigation.
Data boundary	Where data stayed; third-party transmission status	Supports privacy, privilege, and security claims.

This model aligns with the broader direction of AI risk management: accountable and transparent systems, privacy-enhancing design, secure and resilient operation, and explainability appropriate to context (NIST, 2023; NIST, 2024).

6. Visual Framework: Black Box vs. Receipt

The governance difference is easiest to see as a contrast between a black-box workflow and a receipt-producing workflow.

Black-box AI	Governance-receipt AI
Prompt -> answer	Identity -> task -> evidence -> draft -> review -> final output -> audit trail
No stable record of evidence used	Retrieved documents and citations are preserved
Human review may be informal	Reviewer decision is captured
Data path may be hard to prove	Data boundary is recorded
Useful, but difficult to defend	Useful and reconstructable

A receipt does not guarantee perfection. It prevents blindness. When something matters, the organization can reconstruct the event instead of relying on memory, screenshots, or assumptions.

7. The Public Cloud Contrast

Public cloud AI tools can be useful and impressive. For general tasks, they may be entirely appropriate. But regulated workflows raise a different set of questions: Where did the data go? What was transmitted? What was retained? What can be reconstructed later? Who reviewed the output? Can the organization prove that protected or privileged information remained controlled?

HHS OCR has emphasized that regulated entities must consider whether technologies disclose protected health information to third parties in ways that comply with HIPAA (U.S. Department of Health and Human Services, 2024). The same principle becomes sharper when generative systems touch clinical records or workflow data.

The point is not that all cloud AI is wrong. The point is that cloud AI, local AI, and hybrid AI are not interchangeable governance patterns. Architecture determines what can be proven later.

8. The Local Governed Model

A local governed model keeps the highest-risk parts of the workflow under the organization's control: data access, retrieval, inference, review, logging, and export. This does not eliminate every risk, but it makes the system easier to inspect and defend.

Pocono AI's Sentinel Node is designed around this principle. It is a local AI appliance model for high-liability environments. The goal is to support retrieval, drafting, and review while preserving professional accountability and a local audit trail.

The practical design principle is simple: do not bolt governance on after the chatbot. Build the workflow so that evidence capture is part of normal operation.

9. Legal Parallel: Privilege and Professional Responsibility

The same standard applies in law. A paralegal may use AI to summarize internal case files, identify key dates, or prepare a chronology for attorney review. That can be valuable. But the firm must be able to show which documents were used, whether privileged material stayed inside the firm, what the AI generated, what the human reviewer changed, and whether the final work product was used in client advice or filing support.

ABA guidance on generative AI emphasizes that lawyers must consider ethical obligations including competence, confidentiality, communication, supervision, and fees (American Bar Association, 2024). Those duties are difficult to satisfy with blind, unlogged, or uncontrolled AI workflows.

For law firms, the final answer is not the only thing that matters. The path to the answer matters.

10. Questions Buyers Should Ask Before Deploying AI

A medical practice, law firm, or investor evaluating an AI system should ask evidence questions before asking only feature questions.

Buyer question	Why it matters
Can we prove what data was used?	Tests whether retrieval and evidence are logged.
Can we prove who reviewed the output?	Tests whether human oversight is real or informal.

Can we reconstruct the answer six months later?	Tests auditability and defensibility.
Can we prove PHI or privileged data stayed controlled?	Tests privacy, privilege, and data-boundary claims.
Can we export or report the governance receipt?	Tests whether the system supports review, compliance, and investigation.
Can the workflow stop unsafe outputs?	Tests whether review gates exist before final use.

11. Pilot Use Cases

The Governance Receipt framework is most useful where the work is repetitive enough to benefit from AI but consequential enough to require traceability.

Healthcare pilots	Law-firm pilots
Prior authorization appeals	Internal case-file summaries
Denial responses	Legal research memos with citations
Chart summaries for review	Chronologies and issue maps
Referral letter drafting	Discovery review summaries
Policy Q&A against internal documents	Client-file intake summaries

In every case, the pilot should measure not only time saved, but whether the system can produce a receipt: source evidence, reviewer decision, final output, and proof of the data boundary.

12. Implementation Principles

Start narrow. Choose one workflow, one data boundary, one review path, and one measurable outcome.

Make evidence visible. Users should be able to inspect the documents, passages, and citations behind the draft.

Require human gates. The system should support draft generation, not unsupervised final action in high-liability tasks.

Log the right events. Audit records should preserve the sequence of identity, task, retrieval, generation, review, output, and export.

Keep the data boundary simple. The more sensitive the workflow, the more valuable it is to keep retrieval, inference, and audit logging under local control.

Review and improve. A governance receipt is not only defensive. It is also operational intelligence: it shows where prompts fail, evidence retrieval is weak, reviewers intervene, and workflows need redesign.

13. Conclusion

The most important AI systems in healthcare and law will not be the ones that merely sound the most intelligent. They will be the ones that can be governed.

They will preserve evidence. They will protect professional responsibility. They will keep sensitive information within a defensible boundary. They will support human review rather than erase it.

And when a serious organization asks the question that matters - Can we prove what happened? - they will be able to answer.

That is the standard behind the Governance Receipt.

No governance receipt, no accountable AI.

For independent medical practices and small law firms exploring this model, Pocono AI is opening pilot conversations around Sentinel Node deployments.

Source Integrity Note

This paper uses primary government, standards, and professional-responsibility sources wherever possible. The citations below are formatted in APA 7 style. The sources were selected because they are directly relevant to AI risk management, audit controls, health information security, online tracking/data disclosure risk, EHR auditability, and lawyers' professional duties when using generative AI.

This is a strategic governance white paper, not legal, medical, or compliance advice. Organizations should consult qualified counsel and compliance professionals before adopting AI workflows involving protected health information, privileged material, or regulated decision processes.

References

- American Bar Association. (2024, July 29). *ABA issues first ethics guidance on a lawyer's use of AI tools*. <https://www.americanbar.org/news/abanews/aba-news-archives/2024/07/aba-issues-first-ethics-guidance-ai-tools/>
- Electronic protected health information: Technical safeguards, 45 C.F.R. § 164.312. (2026). <https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312>
- Kannampallil, T. G., et al. (2022). Using electronic health record audit log data for research: Insights from early efforts. *Journal of the American Medical Informatics Association*, 30(1), 167-172. <https://pmc.ncbi.nlm.nih.gov/articles/PMC9748594/>
- National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53 Rev. 5). <https://doi.org/10.6028/NIST.SP.800-53r5>
- National Institute of Standards and Technology. (2023). *Artificial intelligence risk management framework (AI RMF 1.0)* (NIST AI 100-1). <https://doi.org/10.6028/NIST.AI.100-1>
- National Institute of Standards and Technology. (2024). *Artificial intelligence risk management framework: Generative artificial intelligence profile* (NIST AI 600-1). <https://doi.org/10.6028/NIST.AI.600-1>
- Office of the National Coordinator for Health Information Technology. (n.d.). *170.315(d)(10) Auditing actions on health information*. <https://healthit.gov/test-method/auditing-actions-health-information/>
- U.S. Department of Health and Human Services. (2024, June 26). *Use of online tracking technologies by HIPAA covered entities and business associates*. <https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/hipaa-online-tracking/index.html>
- U.S. Department of Health and Human Services. (2024, December 30). *Summary of the HIPAA Security Rule*. <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>

Appendix A: Governance Receipt Checklist

Control area	Minimum receipt fields
Identity	User ID; role; authentication context; session timestamp
Task	Prompt; workflow category; patient/matter identifier; risk level
Retrieval	Sources searched; documents retrieved; chunk IDs/passages; citation mapping
Generation	Model/tool used; draft output; safety flags; unsupported-claim warnings
Review	Reviewer ID; decision; edits; approval/rejection; time of review
Output	Final output; export destination; recipient if applicable; version
Boundary	Local/cloud status; external transmissions; BAA/authorization status if relevant
Audit protection	Time stamps; retention policy; tamper-evidence; access logs

Appendix B: Source Verification Matrix

Claim area	Primary source used	Secondary check / rationale
Trustworthy AI requires accountability, transparency, privacy, security and explainability.	NIST AI RMF v1.0, USC 6002	NIST is the authoritative U.S. standards source for AI RMF.
Systems using ePHI require audit controls	45 C.F.R. § 164.312(b); HHS Security Rule summary	Federal regulation and HHS summary align on audit-control requirement.
EHR audit logs preserve time-sequenced data	ONC audit-actions certification guide	Peer-reviewed audit-log literature supports the operational value.
HIPAA-regulated entities must manage third-party risks	HHS OCR risks and technologies guidance	Used only for the general data-disclosure principle, not as AI-specific legal advice.
Lawyers using generative AI must consider confidentiality	ABA Formal Opinion 512 coverage confidentiality	ABA is the primary professional association source for this guidance.